

1. Giới thiệu & Động lực nghiên cứu

Bối cảnh: Micro-data — dữ liệu ghi nhận thông tin về từng cá nhân cụ thể (lịch sử giao dịch, sở thích, đánh giá sản phẩm) — ngày càng được công bố rộng rãi, thúc đẩy bởi luật chính phủ mở và nhu cầu nghiên cứu data mining. Nhiều dataset chứa thông tin nhạy cảm theo luật định (hồ sơ y tế) hoặc thông tin cá nhân mà người dùng kỳ vọng được giữ bí mật.

Vấn đề: Thực hành phổ biến là xóa các trường định danh trực tiếp (tên, địa chỉ, số CMND) trước khi công bố, với kỳ vọng rằng dữ liệu sau đó là "ẩn danh". Điều này là **sai lầm nghiêm trọng**.

Các cuộc tấn công tiêu biểu đã biết:

- **Sweeney (1997):** Kết hợp hồ sơ xuất viện Massachusetts (đã xóa tên) với danh sách cử tri công khai → re-identify bệnh nhân cụ thể.
- **AOL Search Data (2006):** Dữ liệu tìm kiếm "ẩn danh" của 650,000 người dùng bị khai thác để nhận diện cá nhân.
- **DNA Sequences:** Chuỗi ADN ẩn danh bị re-identify qua cross-correlation với dữ liệu y tế khác.

Đóng góp của bài báo (3 điểm chính):

Đóng góp 1 — Mô hình hình thức: Xây dựng mô hình toán học nghiêm ngặt cho privacy breach trong micro-data ẩn danh, không giả định trước quasi-identifier cố định như k-anonymity.

Đóng góp 2 — Thuật toán tổng quát: Đề xuất thuật toán de-anonymization hoạt động dưới các giả định rất nhẹ về phân phối dữ liệu, robust với nhiễu và sanitization, chỉ cần 5–10 thuộc tính auxiliary.

Đóng góp 3 — Case study Netflix: Áp dụng lên Netflix Prize Dataset (500,000 hồ sơ), chứng minh rằng kẻ tấn công chỉ cần biết một ít về subscriber là có thể nhận diện toàn bộ lịch sử xem phim.

2. Khái niệm cơ bản

2.1 Cấu trúc Database

Database **D** được mô hình hóa là ma trận $\mathbf{N} \times \mathbf{M}$, trong đó mỗi hàng là một hồ sơ cá nhân (record), mỗi cột là một thuộc tính (attribute). Với dataset phim: N = số subscriber, M = tổng số phim trong catalog. Mỗi ô có thể là rating (1–5 sao), ngày xem, hoặc $\perp$ (null — không có dữ liệu).

Support của một record r , ký hiệu $\text{supp}(r)$, là tập hợp các thuộc tính non-null — tức là các phim mà subscriber đó thực sự đã đánh giá.

2.2 Sparsity (Tính thưa)

Đây là đặc tính then chốt của micro-data thực tế. Mỗi hồ sơ chỉ có giá trị cho một phần nhỏ trong hàng chục nghìn thuộc tính. Ví dụ: ngay cả người dùng Netflix tích cực nhất cũng chỉ rating vài trăm phim trong tổng catalog hàng chục nghìn đầu.

Phân phối của kích thước support tuân theo **power law / heavy tail**: phim phổ biến có nhiều rating nhưng số phim phổ biến rất ít; phim hiếm chiếm đại đa số entries trong database. Đây là lý do vì sao k-anonymity thất bại hoàn toàn trên loại dữ liệu này.

Định nghĩa hình thức: Database D là (ϵ, δ) -sparse w.r.t. similarity measure Sim nếu:

$$\Pr_r [\text{Sim}(r, r') > \epsilon \ \forall r' \neq r] \leq \delta$$

Nghĩa là: với xác suất $\geq 1 - \delta$, không có record nào trong database gần record r hơn ngưỡng ϵ . Bài báo chứng minh empirically rằng Netflix Prize Dataset là **overwhelmingly sparse** — đại đa số subscriber không có một subscriber nào khác đủ tương đồng trong toàn bộ 500,000 hồ sơ.

2.3 Similarity Measure

Hàm Sim ánh xạ một cặp thuộc tính (hoặc record) vào khoảng $[0, 1]$. Với cặp record r_1, r_2 :

$$\text{Sim}(r_1, r_2) = \sum \text{Sim}(r_{1i}, r_{2i}) / |\text{supp}(r_1) \cup \text{supp}(r_2)|$$

Đây là dạng tổng quát hóa của cosine similarity. Trong case study Netflix, Sim giữa hai thuộc tính = 1 nếu rating và ngày xem nằm trong ngưỡng cho phép, = 0 nếu ngược lại.

2.4 Tại sao k-anonymity thất bại

k-anonymity yêu cầu publisher xác định trước "quasi-identifier" — tập thuộc tính mà adversary có thể biết — và đảm bảo mỗi tổ hợp quasi-identifier xuất hiện ít nhất k lần. Với high-dimensional data, điều này thất bại vì:

- Không thể biết trước adversary sẽ biết thuộc tính nào của từng cá nhân.
- Số lượng tổ hợp tăng theo hàm mũ với số chiều → không thể k-anonymize thực tế.
- Sparsity đảm bảo mỗi record gần như là unique ngay cả khi không dùng tên hay địa chỉ.

3. Mô hình hình thức (Formal Model)

3.1 Mô hình Adversary

Adversary (kẻ tấn công) muốn de-anonymize một record r được lấy ngẫu nhiên từ D . Adversary được cung cấp **auxiliary information** (kiến thức nền):

$$\text{aux} = \text{Aux}(r) \in X^M$$

Đây là một tập con các giá trị thuộc tính của r , có thể không chính xác (perturbed), chọn theo bất kỳ phân phối xác suất nào. Adversary không cần biết trước đây là quasi-identifier hay sensitive attribute — mọi thứ adversary biết về target đều có thể trở thành "identifier" cho hồ sơ đó.

Phân biệt với k-anonymity: Trong k-anonymity, có sự phân chia cứng nhắc quasi-identifier (adversary biết) / sensitive attribute (cần bảo vệ). Trong mô hình này, sự phân chia đó phụ thuộc vào từng cá nhân và không cố định.

3.2 Ba định nghĩa Privacy Breach

Định nghĩa 2 — (θ, ω) -Deanonymization:

Tồn tại thuật toán A : nhận D và $\text{Aux}(r)$, xuất r' sao cho $\Pr[\text{Sim}(r, r') \geq \theta] \geq \omega$

Kẻ tấn công bắt đầu với aux gần r trên một tập nhỏ thuộc tính, rồi tìm r' gần r trên **toàn bộ** tập thuộc tính. Đây là dạng **khuyến đại kiến thức**: từ ít thông tin $\rightarrow$ học được toàn bộ hồ sơ.

Định nghĩa 3 — De-anonymization từ Sample $D' \subset D$:

Vì Netflix chỉ phát hành 1/8 database, cần xử lý trường hợp record của target **chưa chắc có** trong D' :

- Nếu $r \in D'$: xuất r' với $\Pr[\text{Sim}(r, r') \geq \theta] \geq \omega$
- Nếu $r \notin D'$: xuất $\perp$ với xác suất $\geq \omega$

Ngưỡng lỗi $(1-\omega)$ được dùng thống nhất cho cả false positive lẫn false negative — gọi là "equal error rate".

Định nghĩa 4 — Entropic Deanonymization:

$$E[\min_{\{r' \in D', \text{Sim}(r, r') \geq \theta\}} H_S(\Pi, r')] \leq H$$

Adversary xuất tập ứng viên D' và phân phối xác suất Π trên đó. Metric là entropy Shannon tối thiểu của tập ứng viên gần với target. Đây là metric chi tiết hơn: đo lường bao nhiêu bit thông tin còn cần thêm để hoàn tất de-anonymization, không chỉ đo xác suất thành/bại.

Ví dụ điển giải: nếu a priori entropy là 19 bits (không biết gì về target), sau khi chạy thuật toán chỉ cần thêm 3 bits $\rightarrow$ adversary đã giảm được 16 bits thông tin cần thiết.

4. Thuật toán De-anonymization

4.1 Template Tổng quát

Thuật toán có 3 thành phần chính:

Bước 1 — Scoring: Tính $\text{Score}(\text{aux}, r')$ cho mỗi record $r' \in D^*$, đo mức độ tương đồng giữa r' và auxiliary information của adversary.

Bước 2 — Matching: Áp dụng matching criterion lên tập điểm số $\rightarrow$ xác định "matching set". Nếu matching set rỗng $\rightarrow$ xuất $\perp$ (target không có trong sample).

Bước 3 — Selection: Xuất record có điểm cao nhất (theo Định nghĩa 2/3) hoặc xuất phân phối xác suất trên matching set (theo Định nghĩa 4).

4.2 Algorithm 1A — Đơn giản, phân tích được

- **Scoring:** $\text{Score}(\text{aux}, r') = \min_{i \in \text{supp}(\text{aux})} \text{Sim}(\text{aux}_i, r'_i)$ — điểm số bằng thuộc tính kém tương đồng nhất (bottleneck).
- **Matching set:** $D' = \{ r' \in D^* : \text{Score}(\text{aux}, r') > \alpha \}$ với α cố định.
- **Selection:** Phân phối đều trên D' .

Ưu điểm: tractable về mặt lý thuyết, dễ phân tích. Nhược điểm: không tận dụng sự khác biệt giữa thuộc tính phổ biến và hiếm.

4.3 Algorithm 1B — Thực tiễn, tối ưu

Scoring (weighted):

$$\text{Score}(\text{aux}, r') = \sum_{i \in \text{supp}(\text{aux})} \text{wt}(i) \cdot \text{Sim}(\text{aux}_i, r'_i)$$

$$\text{wt}(i) = 1 / \log|\text{supp}(i)|$$

$|\text{supp}(i)|$ là số subscriber đã rating phim i . Phim càng hiếm $\rightarrow$ weight càng cao $\rightarrow$ chứa nhiều thông tin de-anonymization hơn. Ý tưởng: biết target đã xem "The Dedalus Book of French Horror" có giá trị nhận diện cao hơn nhiều so với biết target đã xem Harry Potter.

Matching criterion (eccentricity): Tính $\max$, $\max_2$, σ của tập điểm số. Nếu $(\max - \max_2) / \sigma < \varphi \rightarrow$ không có match (record không nổi bật). Nếu ngược lại $\rightarrow$ match là record có điểm cao nhất. Tham số $\varphi = 1.5$ (eccentricity) đảm bảo record được chọn phải "vượt trội" rõ ràng so với ứng viên thứ hai, hạn chế false positive.

Selection (exponential distribution):

$$\Pi(r') = c \cdot e^{\{\text{Score}(\text{aux}, r') / \sigma\}}$$

Phân phối xác suất exponential theo điểm số, không phân phối đều. Record nào có điểm cao hơn được ưu tiên nhiều hơn, giảm khả năng match ngẫu nhiên là false positive.

Trong Netflix case study, scoring function được cụ thể hóa:

$$\text{Score}(\text{aux}, r') = \sum_{i \in \text{supp}(\text{aux})} \text{wt}(i) \cdot (e^{\{(p_i - p'_i)/1.5\}} + e^{\{(d_i - d'_i)/30\}})$$

với p_i = rating trong aux, p'_i = rating trong candidate record, d_i và d'_i là ngày xem tương ứng, $p_0 = 1.5$, $d_0 = 30$ ngày.

5. Phân tích Lý thuyết

5.1 Trường hợp Tổng quát — Định lý 1

Định lý 1: Cho $\epsilon, \delta \in (0, 1)$. Nếu aux gồm ít nhất

$$m \geq (\log N - \log \epsilon) / (-\log(1 - \delta))$$

thuộc tính được chọn ngẫu nhiên từ record r , với $\text{Sim}(\text{aux}_i, r_i) \geq 1 - \epsilon$ với mọi i , thì D có thể được $(1 - \epsilon - \delta, 1 - \epsilon)$ -deanonymize.

Nhận xét quan trọng:

- m phụ thuộc **logarithm** vào $N \rightarrow$ khi database tăng 1000 lần, số thuộc tính cần biết tăng không đáng kể.
- Phụ thuộc tuyến tính vào $1/\delta \rightarrow$ nếu cho phép accuracy thấp hơn một chút, cần ít background knowledge hơn nhiều.
- False positive rate tổng $\leq N \cdot (1 - \delta)^m$, giảm về 0 khi m đủ lớn.

Ý nghĩa: Ngay cả trong trường hợp tổng quát nhất (không giả định sparse), chỉ cần $O(\log N)$ thuộc tính auxiliary là đủ.

5.2 Dataset Thưa — Định lý 2

Định lý 2: Nếu D là $(1 - \epsilon - \delta, \epsilon)$ -sparse, thì D có thể được $(1, 1 - \epsilon)$ -deanonymize.

Với sparse database, matching set chứa **đúng 1 record**: chính là record đúng của target. Xác suất false positive gần bằng 0. Đây chính là trường hợp của Netflix Dataset.

Hệ quả thực tế: Sparsity không chỉ là đặc tính kỹ thuật — nó là lý do vì sao de-anonymization **chính xác hơn** trên dữ liệu thực tế so với dự đoán worst-case.

5.3 k-Deanonymization — Định lý 3

Định lý 3: Với D là $(1 - \epsilon - \delta, \epsilon)$ -sparse và $m = \log(N/(k-1)) / \log(1/(1-\delta))$:

- D có thể được $(1, 1/k)$ -deanonymize $\rightarrow$ record đúng nằm trong top- k ứng viên với xác suất $\geq 1/k$.
- D có thể được $(1, \log k)$ -deanonymize entropically $\rightarrow$ adversary chỉ cần thêm $\log k$ bits để hoàn tất.

Hàm ý: Ngay cả khi adversary chỉ "k-deanonymize" (xuất k ứng viên thay vì 1), điều này cũng đủ nguy hiểm nếu k nhỏ — và k nhỏ vì m cần thiết giảm theo logarithm.

5.4 De-anonymization từ Sample — Định lý 4 & 5

Định lý 4: Thuật toán hoạt động đúng ngay cả khi chỉ có $D^* \subset D$: nếu $r \in D^*$ thì de-anonymize thành công; nếu $r \notin D^*$ thì xuất $\perp$ đúng — cả hai với xác suất $\geq 1-\epsilon$.

Định lý 5: Nếu D không phải (ϵ, δ) -sparse, thì random $1/\lambda$ -subset D^* không phải $(\epsilon, \delta\gamma/\lambda)$ -sparse với xác suất $\geq 1-\gamma$.

Ý nghĩa thực tiễn: Sparsity của sample ngụ ý sparsity của toàn bộ database gốc (với xác suất cao). Không thể "ẩn" sparsity bằng cách chỉ publish sample — và nếu cố tình phá vỡ sparsity của sample, dataset sẽ mất utility cho collaborative filtering (điều mà Netflix không muốn).

6. Case Study: Netflix Prize Dataset

6.1 Bối cảnh

Tháng 10/2006, Netflix công bố dataset gồm **100,480,507 ratings** của **480,189 subscribers** (từ 12/1999 đến 12/2005) để hỗ trợ cuộc thi Netflix Prize (\$1 triệu USD cho thuật toán recommendation tốt nhất). Đây là khoảng 1/8 tổng số subscriber Netflix cuối năm 2005.

Tuyên bố của Netflix (FAQ):

"Không có thông tin định danh khách hàng nào trong dataset. Ngay cả khi bạn biết toàn bộ ratings của mình, bạn cũng khó nhận ra chúng vì chỉ có sample nhỏ và dữ liệu đã bị perturbation."

Thực tế (theo phân tích của bài báo): Tuyên bố này sai ở mọi điểm.

6.2 Mức độ Perturbation thực tế

Bài báo kiểm chứng bằng cách lấy lịch sử rating từ Netflix website của một số người quen (biết tên thật) rồi tìm trong dataset. Kết quả: một subscriber có 1/306 ratings bị thay đổi, subscriber khác có 5/229 ratings bị thay đổi. **Mức nhiễu quá nhỏ** để ảnh hưởng đến thuật toán robust. Dataset cũng không hề được k -anonymize ($k > 1$).

Lý do Netflix không thể perturbation nhiều: dataset được publish để cải thiện recommendation algorithm. Nhiễu lớn sẽ phá vỡ cross-attribute correlations → dataset mất giá trị cho mục đích nghiên cứu — đi ngược lại mục tiêu của Netflix Prize.

6.3 Thiết lập thực nghiệm

Similarity function: Ngưỡng threshold — Sim = 1 nếu rating trong khoảng ± 0 hoặc ± 1 sao, ngày xem trong khoảng ± 3 hoặc ± 14 ngày (hoặc ∞ nếu không có ngày). Cũng cho phép một phần auxiliary information hoàn toàn sai: "aux gồm m phim trong m_0 " nghĩa là m_0 phim được cung cấp nhưng chỉ m phim thực sự đúng.

Eccentricity: $\phi = 1.5$ — matching được xác nhận khi điểm cao nhất vượt điểm thứ 2 ít nhất 1.5 lần độ lệch chuẩn.

6.4 Kết quả De-anonymization

Với exact ratings và approximate dates:

- **2 phim, ± 14 ngày:** ~43% hồ sơ được nhận diện uniquely
- **2 phim, ± 3 ngày:** ~68% hồ sơ được nhận diện
- **3 phim đúng trong 4 phim biết, ± 14 ngày:** ~70%
- **6 phim đúng trong 8 phim biết, ± 14 ngày:** 99% hồ sơ được nhận diện

Không có ngày xem (chỉ ratings):

- 6/8 phim ngoài top-500 most-rated: **84%** hồ sơ được nhận diện — ngay cả khi hoàn toàn không biết thời điểm xem.

Về entropic de-anonymization:

- A priori entropy: ~19 bits (không biết gì về target)
- Với 2 phim: entropy giảm còn ~4-5 bits cần thêm
- Với 6/8 phim: entropy giảm xuống dưới 1 bit — gần như xác định hoàn toàn

Phát hiện record không trong sample: Thuật toán đồng thời phát hiện chính xác khi record của target không nằm trong 1/8 được publish, với accuracy tương đương (Figure 2 trong paper).

6.5 IMDb Cross-Correlation — Proof of Concept

Bài báo sử dụng ratings công khai trên IMDb (Internet Movie Database) làm auxiliary information. Lý do: người dùng Netflix thường cũng rate phim trên IMDb với tên thật hoặc username có thể truy vết.

Thách thức thực tế của IMDb aux:

- Nhiều phim trên IMDb không có trên Netflix và ngược lại.

- Một số ratings trên IMDb không có điểm số (chỉ có comment).
- Ngày rating IMDb và Netflix có thể không tương quan.

Kết quả: Với sample nhỏ vài chục IMDb users (giới hạn bởi ToS của IMDb), thuật toán nhận diện thành công **2 users** với eccentricity 28σ và 15σ — tức là record được chọn vượt xa ứng viên thứ 2 tới 28 độ lệch chuẩn. Đây là match cực kỳ mạnh, xác suất false positive gần bằng 0.

Thông tin nhạy cảm bị phơi bày từ 1 user được de-anonymize:

- Quan điểm chính trị: Rating mạnh về "Power and Terror: Noam Chomsky" và "Fahrenheit 9/11"
- Quan điểm tôn giáo: Rating "Jesus of Nazareth" và "The Gospel of John"
- Thái độ sức khỏe: Không thích "Super Size Me"
- Xu hướng tình dục: Rating 1 sao cho "Bent" và "Queer as Folk"

Tất cả thông tin này không thể suy ra từ ratings công khai trên IMDb của người đó — chỉ xuất hiện trong hồ sơ Netflix riêng tư.

7. Hàm ý & Kết luận

7.1 Hàm ý pháp lý & chính sách

Netflix vi phạm privacy policy của chính mình: Policy của Netflix phân chia thông tin thành "personal" và "non-personal", khẳng định ratings là non-personal và có thể dùng ẩn danh. Bài báo chứng minh sự phân chia này là **false dichotomy** — ratings khi kết hợp với nhau và với background knowledge trở thành thông tin định danh.

"Forward Privacy" bị phá vỡ: Một khi dữ liệu đã bị link với danh tính thật, mọi bí danh tương lai của người đó đều có thể bị phá vỡ. Ví dụ: Alice bị de-anonymize từ Netflix. Kể từ đó, bất kỳ virtual identity "Ecila" nào Alice tạo ra đều không thể tiết lộ thông tin về phim đã xem mà không bị truy vết về Alice thật.

Hàm ý cho data protection law: Cần định nghĩa lại "anonymized data" dựa trên rủi ro re-identification thực tế, không chỉ dựa trên việc đã xóa các trường tên/địa chỉ.

7.2 Hàm ý kỹ thuật

Removing PII không đủ: Bản chất của micro-data high-dimensional là mỗi hồ sơ gần như unique trong không gian thuộc tính — ngay cả khi không có tên hay địa chỉ.

k-anonymity thất bại hoàn toàn trên high-dimensional data: Được chứng minh cả lý thuyết (Aggarwal 2005) lẫn thực nghiệm. Không thể áp dụng k-anonymity cho dataset loại Netflix.

Perturbation nhỏ không có tác dụng: Thuật toán được thiết kế explicit để robust với nhiễu. Chỉ khi mức perturbation đủ lớn để phá vỡ utility của dataset thì mới có tác dụng bảo vệ — nhưng lúc đó dataset không còn dùng được cho mục đích ban đầu.

Differential Privacy là hướng đúng: Bài báo không đề xuất giải pháp cụ thể nhưng ngụ ý rằng cần cơ chế mạnh hơn k-anonymity, có bảo đảm toán học về privacy ngay cả khi adversary có background knowledge tùy ý — đây là định hướng của Differential Privacy (Dwork 2006).

7.3 Về tầm quan trọng của Privacy Netflix

Câu hỏi không phải là "người dùng trung bình có coi trọng lịch sử xem phim không?" mà là "**có user nào** bị tổn hại bởi việc công bố không?" — và câu trả lời rõ ràng là có. Thông tin về xu hướng chính trị, tôn giáo, tình dục có thể là nhạy cảm ngay cả khi người dùng không chủ động che giấu thông tin đó trên các platform khác.

7.4 Kết luận

Bài báo chứng minh rằng **micro-data high-dimensional không thể được bảo vệ bằng cách xóa tên** — đây là giới hạn cơ bản của privacy trong công bố dữ liệu công khai. Thuật toán de-anonymization hoạt động dưới:

- Giả định rất nhẹ về phân phối dữ liệu
- Chỉ cần 2–8 thuộc tính auxiliary
- Robust với nhiễu lên tới 2/8 attributes sai và sai ngày ≤ 14 ngày
- Có thể detect khi target không có trong sample

Hướng nghiên cứu tiếp theo được tác giả đề xuất: khai thác mạng xã hội và cluster structure từ anonymous records để tăng cường de-anonymization thêm nữa; và thiết kế privacy mechanisms mạnh hơn (Differential Privacy) phù hợp cho collaborative filtering.